

# Báo cáo kiểm thử API HW06 — MSSV 23127326

## 1. Phạm vi và oracle

SUT là EShop backend chạy tại `http://localhost:3000`, pin ở upstream commit `85af3ba875c88283615e22cb108f13e2fccaf0e9`. Ba feature được chọn đúng ba pool là FR-04, FR-10 và FR-19. Oracle lấy từ `api_specification.md` và SRS/README của SUT; implementation chỉ dùng để điều tra sau khi test đã quan sát sai lệch.

Quy ước status: 2xx cho thao tác hợp lệ; 400 cho input/business transition không hợp lệ; 401 cho thiếu/sai xác thực; 403 cho đã xác thực nhưng sai quyền; 404 cho resource không tồn tại. Mỗi case có exact status, schema/invariant và postcondition rõ ràng.

## 2. Sinh test bằng AI, kiểm toán và mở rộng

AI được điều khiển theo bốn interaction: AI-001 chuẩn hóa contract, AI-002 sinh FR-04 (40 case), AI-003 sinh FR-10 (45 case), AI-004 sinh FR-19 (40 case). Sinh viên tự audit từng dòng, sửa oracle/fixture/mapping và tự bổ sung 15 case HUMAN (5 mỗi feature). Catalogue cuối cùng có 140/140 nhãn `VALID`; các cột `AI source`, `Audit reason`, `Corrected version`, `Why AI missed` giữ vết quyết định.

Chi tiết audit và mapping Postman nằm trong `test-cases/23127326.csv` và JSON tương đương.

## 3. Độ bao phủ theo tính năng

### FR-04 — Quản lý hồ sơ cá nhân (45 case)

`GET /api/users/me` kiểm tra token, identity binding, exact object schema, sensitive fields và tính lặp lại.  
`PUT /api/users/me` bao phủ phone 10/11 chữ số bắt đầu bằng 0, name/address boundary, null/type, empty/partial body, email/role mass assignment, XSS text và cross-user isolation.

### FR-10 — Máy trạng thái đơn hàng (50 case)

Suite bao phủ ma trận 5x5 giữa `pending`, `confirmed`, `shipping`, `delivered`, `canceled`; valid path `pending` → `confirmed` → `shipping` → `delivered`; cancellation từ `pending/confirmed`; terminal state, backward/skip/replay transition, ownership, admin role, malformed status/ID và response schema. Mỗi case tạo order riêng và GET lại để kiểm tra state.

### FR-19 — Quản lý người dùng phía Admin (45 case)

`GET /api/admin/users` kiểm tra admin-only, token, list schema và absence of credential fields.  
`DELETE /api/admin/users/:id` kiểm tra valid/missing/malformed ID, repeated/concurrent delete, SQL-injection payload, IDOR/regular user, stale JWT, self-delete và postcondition user list. Self-delete chạy cuối suite.

## Ánh xạ yêu cầu bảo mật

SEC-01 được quan sát qua việc API làm lộ plaintext password và các case privacy; SEC-02 qua token missing/invalid/stale; SEC-03 qua admin-role enforcement; SEC-04 qua XSS payload được lưu/round-trip dưới dạng data (UI escaping nằm ngoài phạm vi API); SEC-05 qua injection payload và state invariants; SEC-06 qua

protected `role` . Các test ID và mapping cụ thể được tổng hợp trong Phụ lục AI Audit. SEC-07 chỉ áp dụng OTP reset-password FR-03 nên được ghi `N/A` cho ba API đã chọn, không bịa test OTP ngoài phạm vi.

## 4. Triển khai bộ kiểm thử trên Postman - MSSV 23127326

Full collection gồm hai setup login và 140 catalogue item. Collection-level pre-request script bắt buộc `studentId` , upsert header `X-Student-Id` và log request. Fixture cô lập, cleanup và postcondition được thực hiện bằng `pm.sendRequest` . Assertions kiểm tra exact status, JSON content type, body shape, identity/state và không có 5xx không xử lý.

Tính năng đã dùng: collection/folder, environment/collection/local variables, pre-request/test scripts, dynamic fixtures, data-driven CSV, Collection Runner-compatible data, Newman CLI, JSON/HTML Extra reports và CI artifact. Monitor/mock server không phù hợp vì suite cần reset local SQLite và chạy fixture phá hủy có kiểm soát.

Mỗi feature được tính là một API nghiệp vụ theo đề bài và có từ 35 test case trở lên; các endpoint thành phần vẫn được kiểm thử riêng: FR-04 có GET/PUT, FR-10 có status/cancel, FR-19 có list/delete.

## 5. Kết quả thực thi

Full run ngày 2026-09-01 trên clean database:

| Chỉ số                                   | Kết quả |
|------------------------------------------|---------|
| Test case trong catalogue                | 140     |
| Catalogue PASS / FAIL                    | 98 / 42 |
| HTTP request, gồm setup và postcondition | 467     |
| Assertion                                | 839     |
| Assertion thất bại                       | 63      |
| Lỗi fixture/request                      | 0       |
| Lỗi gốc                                  | 10      |

Data-driven FR-04 phone run: 6 iterations, 12 requests, 18 assertions, 4 fail. Hai valid partition pass; bốn invalid partition bị SUT chấp nhận sai. Báo cáo: `newman-full-report.html` , `newman-report.html` ; phân loại chi tiết: `failure-classification.md` .

## 6. Phân tích lỗi

42 case fail quy về 10 root defects: mass assignment role, credential exposure, missing phone validation, unsafe partial/body update, hai sai state rule FR-10, missing admin-role enforcement, delete-user success sai semantics, stale JWT và self-delete. Không đếm mỗi assertion fail thành một bug. Reproduction, expected/actual, severity, test IDs và public GitHub Issue nằm trong `bug-reports.md` .

## 7. Tích hợp CI/CD

Workflow `.github/workflows/hw06-23127326.yml` clone/pin SUT, khởi động database sạch, validate secret MSSV, chạy Newman và upload report. Chế độ mặc định `full-pass` áp dụng `submit/ci/sut-conformance-fixes.patch` vào clone SUT tạm thời rồi chạy **chính full collection 140 case**; lần xác nhận cục bộ đạt 467 request, 839 assertion và 0 assertion fail. Chế độ `workflow_dispatch: conformance` chạy cùng full collection trên SUT upstream nguyên bản và giữ 42 catalogue case/63 assertion product defect hiển thị màu đỏ. `ci-demo` chỉ là pipeline-control evidence: 22/22 pass hoặc đúng 1 controlled failure, không dùng để đại diện cho full suite.

## 8. Thiết kế Agent Skill

Thiết kế reusable generator có contract normalizer, bốn planner domain/state/security/schema, candidate critic/deduplicator, human approval gate, exporter và execution feedback loop. Skill thực thi được mô tả tại `agent-skill/api-test-generator/SKILL.md`, schema catalogue tại `agent-skill/api-test-generator/references/test-case-schema.md`, pseudocode tại `agent-skill/pseudocode.md`. Theo ràng buộc chống gian lận, sơ đồ nộp cuối phải do sinh viên tự vẽ; AI chỉ cung cấp checklist nút/cạnh trong `agent-skill/skill-design.md`.

Video demo Agent Skill: [DemoAgentSkill-HW06](#).

## 9. Phụ lục A - Báo cáo kiểm toán AI

### A.1. Khai báo sử dụng AI

Tôi sử dụng Codex cho các công việc: trích xuất yêu cầu, phân tích contract và rủi ro, soạn test case, hỗ trợ audit từng dòng, triển khai fixture/Postman/CI, đối soát kết quả và cấu trúc tài liệu. Sinh viên chịu trách nhiệm về oracle cuối, bản sửa, thực thi và quyết định lỗi.

### A.2. Nhật ký tương tác

**AI-001 - 2026-08-31; batch ghi nhận lúc 23:31:15 +07:00**

- Tên công cụ AI: Codex.
- Prompt: Trích xuất contract endpoint FR-04, FR-10 và FR-19 từ `api_specification.md` và SRS chuẩn tắc. Liệt kê actor, input, output, role, đồ thị trạng thái và quy tắc SEC liên quan. Đánh dấu giả định schema/status chưa được quy định.
- Output: Danh mục chuẩn hóa cho các endpoint đã chọn, actor, giả định status và ánh xạ SEC-01-SEC-07; xác định SEC-07 thuộc FR-03 và FR-19 không có endpoint cập nhật role.
- Quyết định sinh viên: Chấp nhận danh mục endpoint, ghi SEC-07 là N/A và không bịa endpoint.

**AI-002 - 2026-08-31; batch ghi nhận lúc 23:31:15 +07:00**

- Tên công cụ AI: Codex.
- Prompt: Với FR-04, tạo ít nhất 40 API test case khác nhau; phân hoạch phone/name/address; bao phủ xác thực, identity binding, mass assignment, trường nhạy cảm, XSS và schema; gồm precondition, data, expected result, cleanup và traceability.
- Output: 40 ứng viên FR-04, được lưu và truy vết bằng `AI-001 - AI-002` trong catalogue JSON.
- Quyết định sinh viên: Viết lại fixture cô lập, status chính xác và postcondition; giữ 40 case sau audit.

#### AI-003 - 2026-08-31; batch ghi nhận lúc 23:31:15 +07:00

- Tên công cụ AI: Codex.
- Prompt: Với FR-10, tạo ma trận chuyển trạng thái 5x5, cùng case hủy, ownership, role, replay, status sai, terminal state và schema; không bị endpoint.
- Output: 45 ứng viên FR-10 bao phủ transition và biến thể bảo mật/schema.
- Quyết định sinh viên: Gắn từng transition với fixture order riêng, xác minh state graph và thêm GET postcondition.

#### AI-004 - 2026-08-31; batch ghi nhận lúc 23:31:15 +07:00

- Tên công cụ AI: Codex.
- Prompt: Với FR-19, tạo ít nhất 40 case chỉ cho list/delete; bao phủ phân quyền Admin, IDOR, self-delete, ID sai, SQL injection, privacy và schema; loại ý tưởng cập nhật role ngoài contract.
- Output: 40 ứng viên FR-19 cho list/delete.
- Quyết định sinh viên: Dùng user một lần cho ca phá hủy, đặt self-delete cuối và loại endpoint không tồn tại.

Phần audit từng dòng, sửa test case và bổ sung 15 case HUMAN được sinh viên thực hiện thủ công sau các interaction trên. Do bản ghi phiên chỉ lưu thời điểm batch, không còn timestamp riêng đáng tin cậy cho từng interaction; không suy diễn thêm thời gian. Kết quả execution, bug classification, CI evidence và việc hoàn thiện package cũng được sinh viên tự kiểm tra và ghi nhận.

### A.3. Kết quả audit và trách nhiệm con người

125 case AI tạo được audit theo từng dòng; 15 case HUMAN được bổ sung riêng. Catalogue cuối có 140/140 case mang nhãn **VALID**, với các trường **Audit reason**, **Corrected version**, **Why AI missed**, **Execution status** và **Evidence**. Output có cấu trúc đầy đủ được lưu tại **test-cases/23127326.json**; báo cáo riêng **ai-audit-report.md** là bản sao thuận tiện để kiểm tra.

### A.4. Hạn chế AI và nguyên tắc rút ra

AI thường nhầm một ý tưởng kiểm thử hợp lý với một test case có thể thực thi, dùng fixture seed không cô lập, đưa ra status thay thế mơ hồ và đôi khi nhầm token User với token Admin. Ma trận state cũng có thể trông đầy đủ nhưng thiếu cách tạo trạng thái ban đầu đáng tin cậy. Vì vậy mọi case phải được người học xác minh bằng contract, fixture, oracle exact, postcondition và kết quả Newman trước khi chấp nhận.

## 10. Tính xác thực của minh chứng và phần bàn giao thủ công

Không dùng console/Issue card dựng. Ảnh GitHub Issues và Actions phải chụp trực tiếp trang thật; Postman Console và Newman hostname phải chụp từ run thật. Danh sách tên file/URL cần chụp nằm trong **evidence/README.md**. Video demo Agent Skill được đính kèm tại [DemoAgentSkill-HW06](#). Sinh viên export PDF/XLSX và đóng ZIP sau cùng.